Information Systems Security Policy (ISSP) for SRI Pay online

By :

- **KOKOLO Wilfride Daïna**
- **ABOMBI GANKOUI Noryl Caleb Jordy**
- **GAMI OKO Jonas M.**
- **ENGAMBET Isaac**

I. Introduction :

Protecting customer data is the number one priority, especially when it comes to sensitive information such as credit card details. With the surge in cyberattacks, companies like **SRI Pay En Ligne** must adopt a proactive approach. This **ISSP** (Information Systems Security Policy) outlines the security rules, the measures to be implemented, and the emergency plans in the event of an incident. It complies with standards such as the Congolese Law No. 29-2019 on the protection of personal data and the **PCI DSS** (Payment Card Industry Data Security Standard).

II. Key Objectives of the ISSP

1. Protecting Sensitive Data

The goal is to block unauthorized access to critical customer information, such as card numbers or personal data, using tools like encryption or multi-factor authentication. This aligns with **Article 63 of Law 29-2019**, which mandates the confidentiality of personal data.

Example: Only authorized employees are granted access to the database.

2. Ensuring Service Continuity

The goal is to prevent interruptions caused by attacks by staying prepared: regular backups, robust firewalls, and a disaster recovery plan.

Example: In the event of a cyberattack, data is quickly restored to prevent a total system shutdown.

3. Regulatory Compliance

We adhere to regulations such as Congolese Law No. 29-2019 and international security standards, not only to avoid fines and legal issues but, more importantly, to protect the rights and freedoms of the individuals involved. For instance, according to **Article 7 of Congolese Law 29-2019**, customer data is kept only for as long as necessary for its processing and, strictly, with their consent.

4. Strengthening Trust

The more we demonstrate that data is well-protected, the more secure our customers feel. This strengthens the bond of trust between the client and the company.

Example: A secure website (featuring the HTTPS padlock) reassures users when making online payments.

III. The 10 Selected Policies

Here are 10 policies covering all security aspects to ensure comprehensive protection:

Policy	Objective	Practical Example
1. Access Management	Limit access to critical resources.	Access to the customer database is restricted to authorized developers only.
2. Data Securing	Protect sensitive customer information.	Credit card numbers display only the last 4 digits (masking).

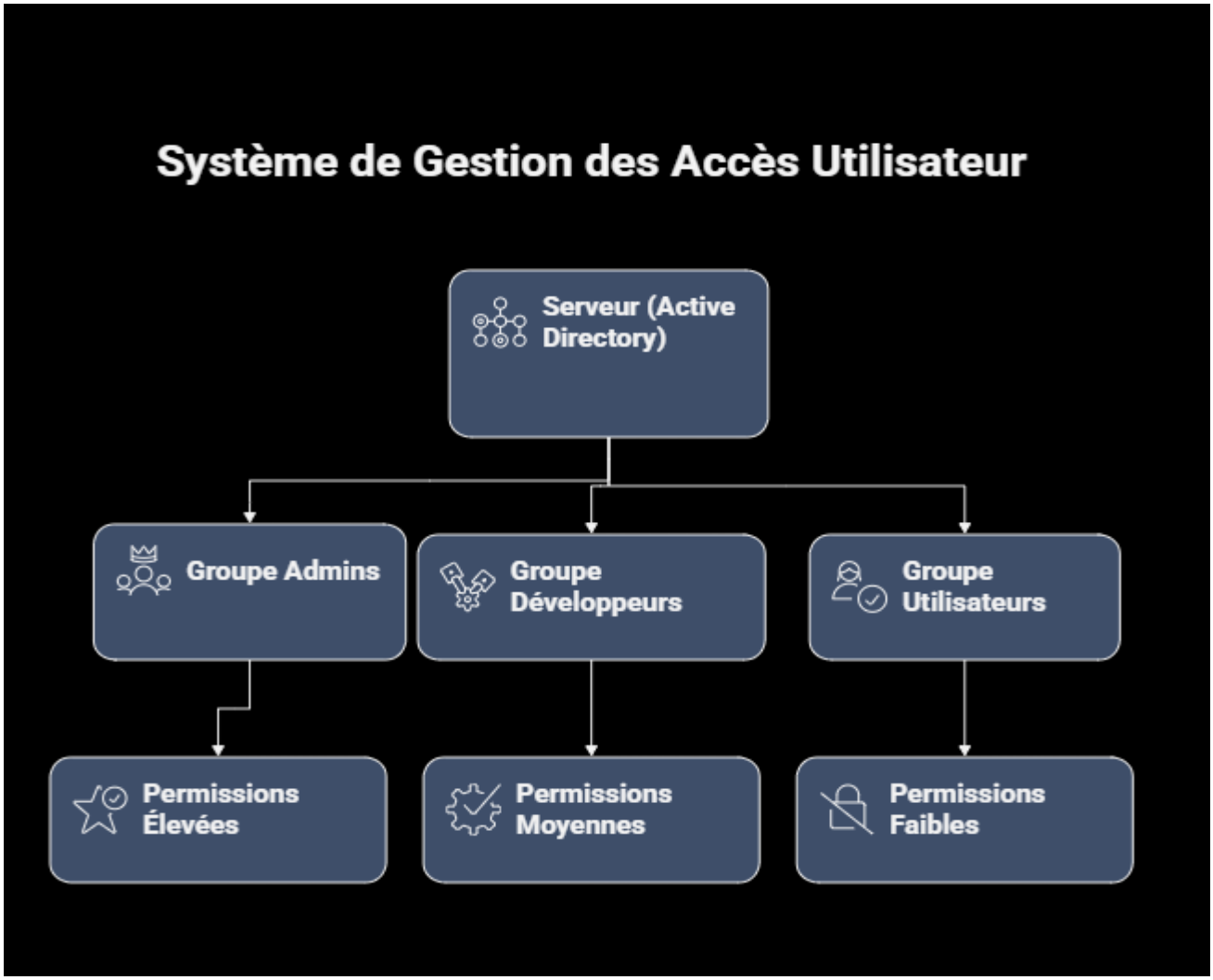
3. Password Security	Strengthen authentication.	All employees must change their passwords every 90 days, for example.
4. Application Security	Protect Web applications.	A Web Application Firewall (WAF) blocks SQL injection attempts on the payment portal.
5. Backup Management	Prevent data loss.	Customer database backups are replicated, for example, in the AWS cloud.
6. Incident Management	Respond to breaches and incidents.	A detected phishing incident is analyzed using SIEM alerts.
7. Network Security	Block attacks on infrastructure.	Remote employees access the network via a VPN with Multi-Factor Authentication (MFA).
8. Updates & Patching	Fix vulnerabilities.	A critical flaw on Windows Server is patched within 24 hours.
9. Training & Awareness	Reduce human error.	Phishing simulation campaigns identify employees who need further awareness training.
10. Compliance & Audit	Adhere to standards and laws.	An annual audit ensures ongoing PCI DSS compliance.

IV. Policy details

1. Access Management Policy:

Using **Active Directory (AD)** enables efficient user management. Only those who truly need it can access critical data. This aligns with **Requirement 7 of the PCI DSS standard**, which consists of restricting access to data based on the "need-to-know" principle.

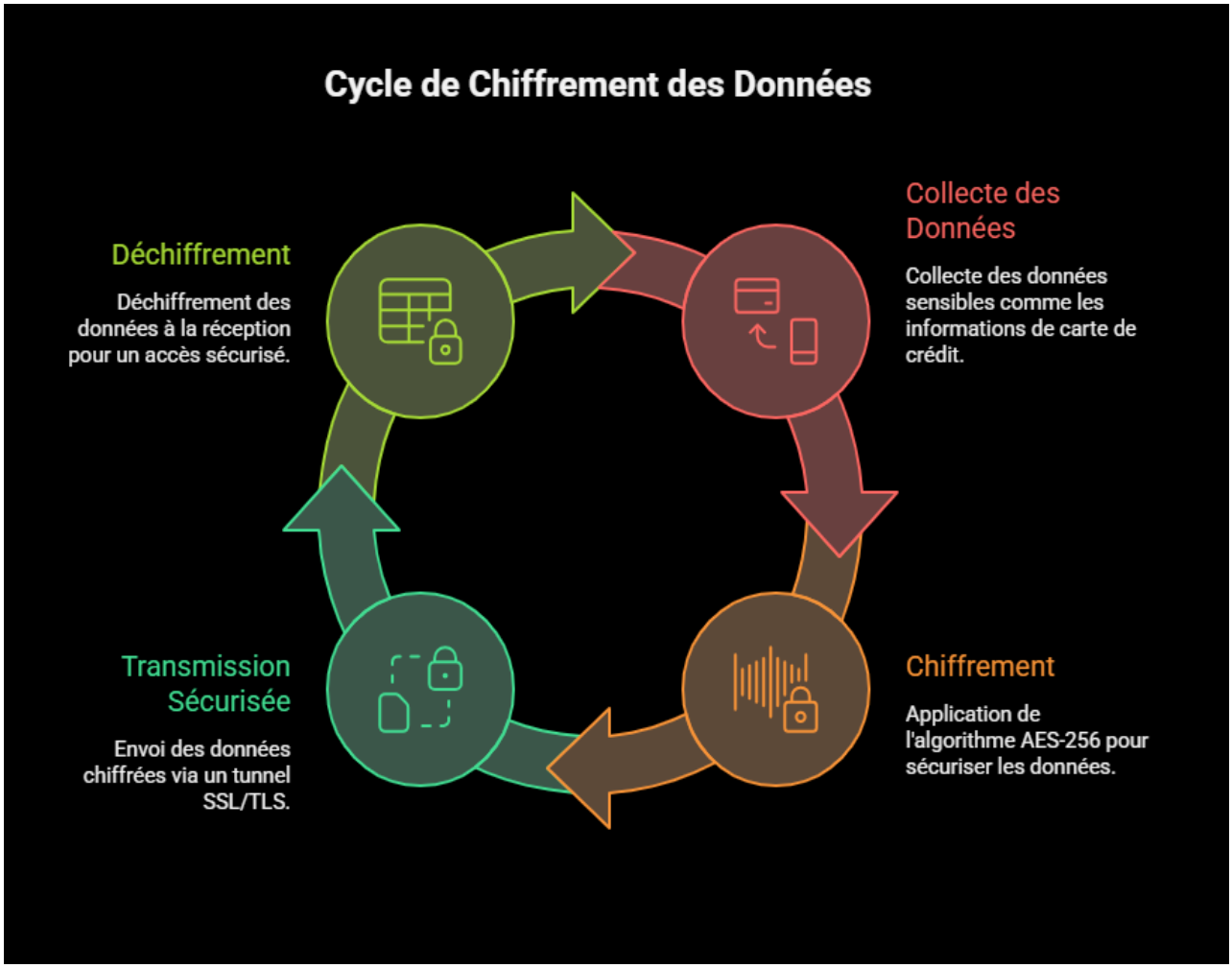
Example: If a developer changes projects, their access rights are immediately adjusted.



2. <u>Data Security Policy</u>

All data in transit uses **SSL/TLS** to protect against eavesdropping. Sensitive databases are encrypted using **AES-256**. This policy complies with **Requirement 3 of the PCI DSS standard** (protecting stored data via AES-256 encryption) as well as **Requirement 4** (encrypting the transmission of data over public networks via SSL/TLS).

<u>Example</u>: Customers paying via the website see a padlock in the URL bar, indicating that the connection is secure.



3. Password Security Policy

Weak or reused passwords are strictly prohibited. Every user must configure a complex and unique password, which aligns with **Requirement 8 of the PCI DSS standard**. This requirement mandates the identification and authentication of access to system components, specifically through unique IDs and **Multi-Factor Authentication (MFA)**.

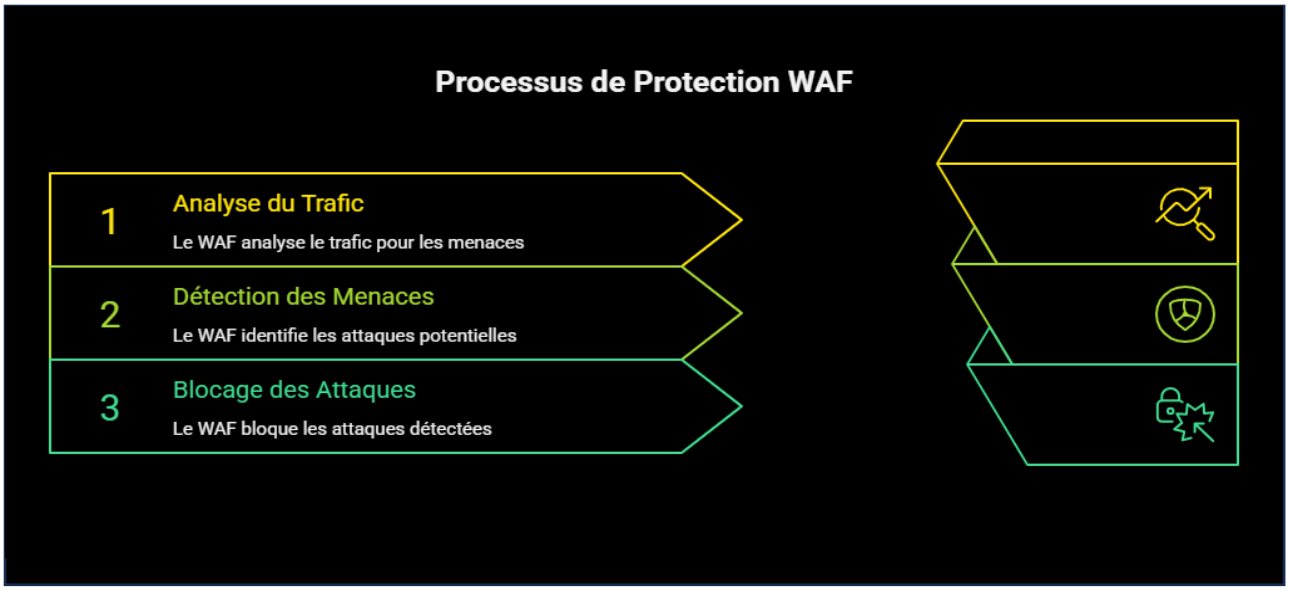
Example: If an employee forgets their password, a secure reset process is available through **Active Directory (AD)**.

4. Application Security Policy

Applications are tested against common attacks (such as **SQL injection** and **XSS**) and secured using **IIS** (Internet Information Services). The development team follows **OWASP** recommendations.

Example: Before a new feature is deployed to production, a **penetration test** (pentest) is conducted by an external provider.

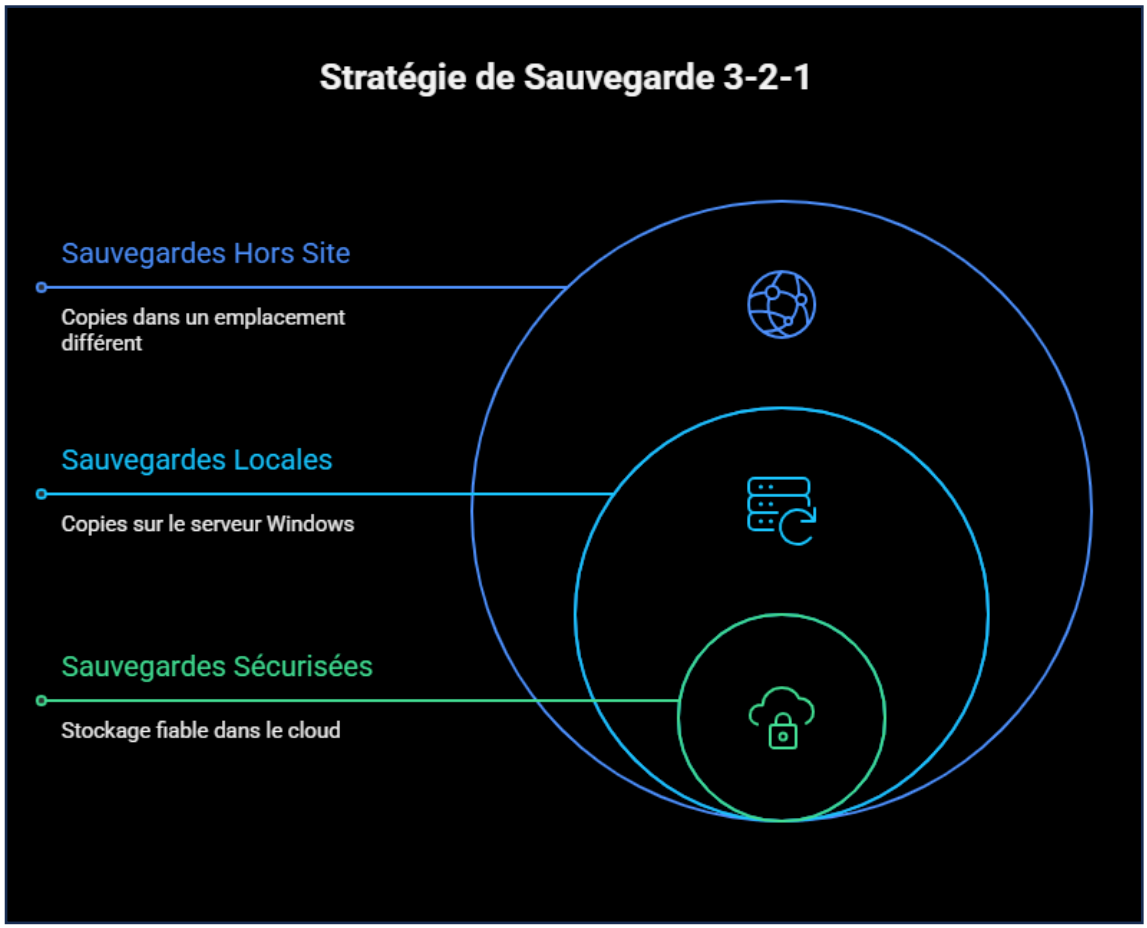
.



5. Backup Management Policy

Backups are scheduled daily and regularly verified to ensure they are recoverable using **Windows Server Backup**.

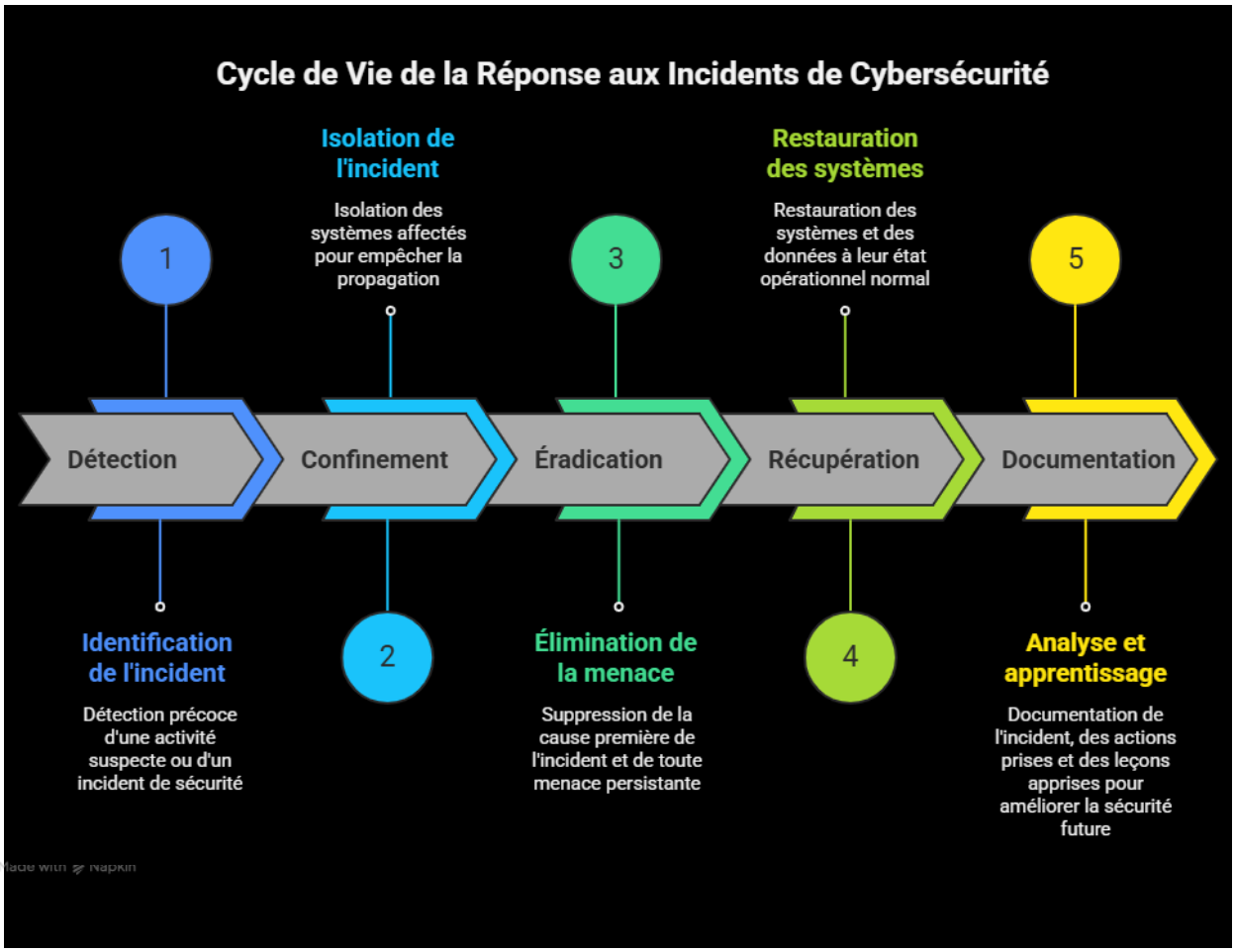
Example: In the event of a server failure, critical data is restored in less than an hour thanks to cloud backups.



6. Incident Management Policy

Establish an incident response chain with clearly defined roles and responsibilities.

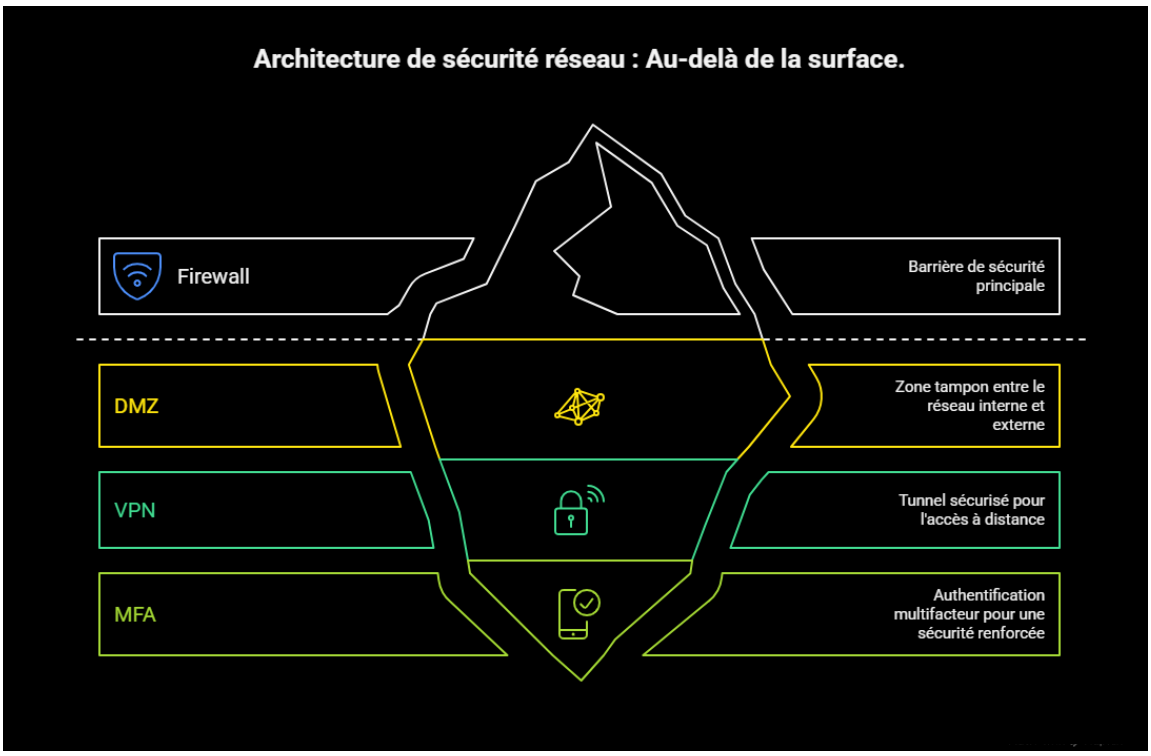
Example: If a ransomware attack is detected, the team disconnects the infected systems to contain the damage and limit further impact.



7. Network Security Policy

Network firewalls enforce strict rules. All remote connections must pass through a **VPN** with **Multi-Factor Authentication (MFA)**. This policy complies with **Requirement 1 of the PCI DSS**, which mandates the installation and maintenance of a firewall configuration to protect cardholder data.

Example: External consultants can only access the internal network using a temporary and secured account.



:

8. Patch and Update Policy

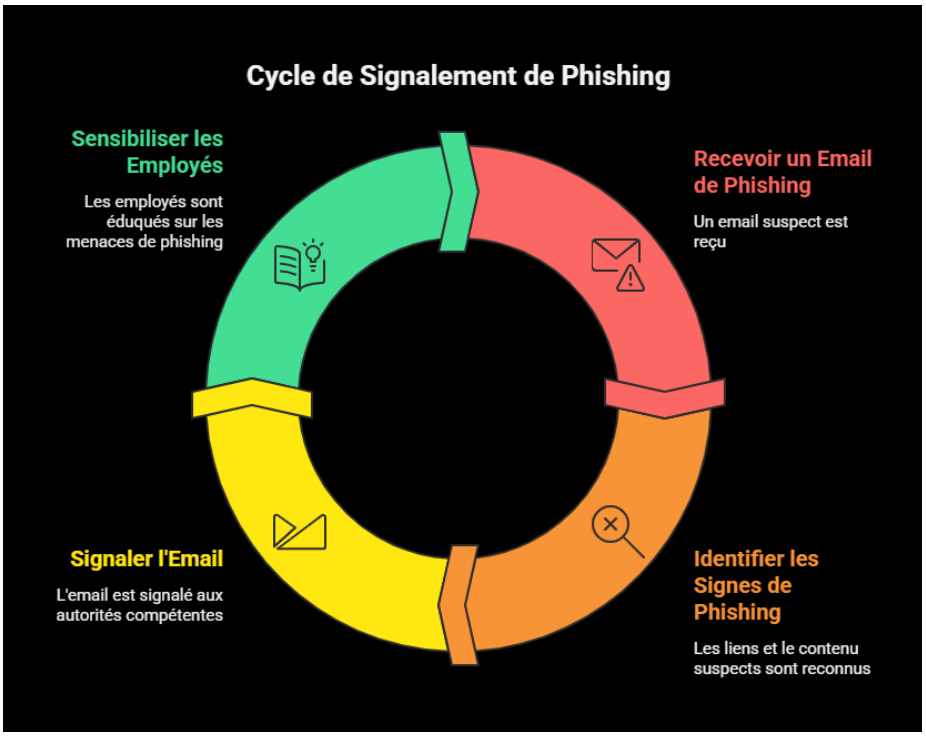
All systems must be kept up to date through a centralized process such as **WSUS** (Windows Server Update Services). This aligns with **Requirement 6 of the PCI DSS**, which calls for developing and maintaining secure systems and applications, specifically through the timely application of security patches—WSUS in our case.

Example: A critical vulnerability alert published by Microsoft is applied to all servers within 48 hours.

9. Training and Awareness Policy

Organize interactive sessions to explain threats such as **phishing**.

Example: A simulation demonstrates how clicking on a fraudulent link can compromise an entire network.

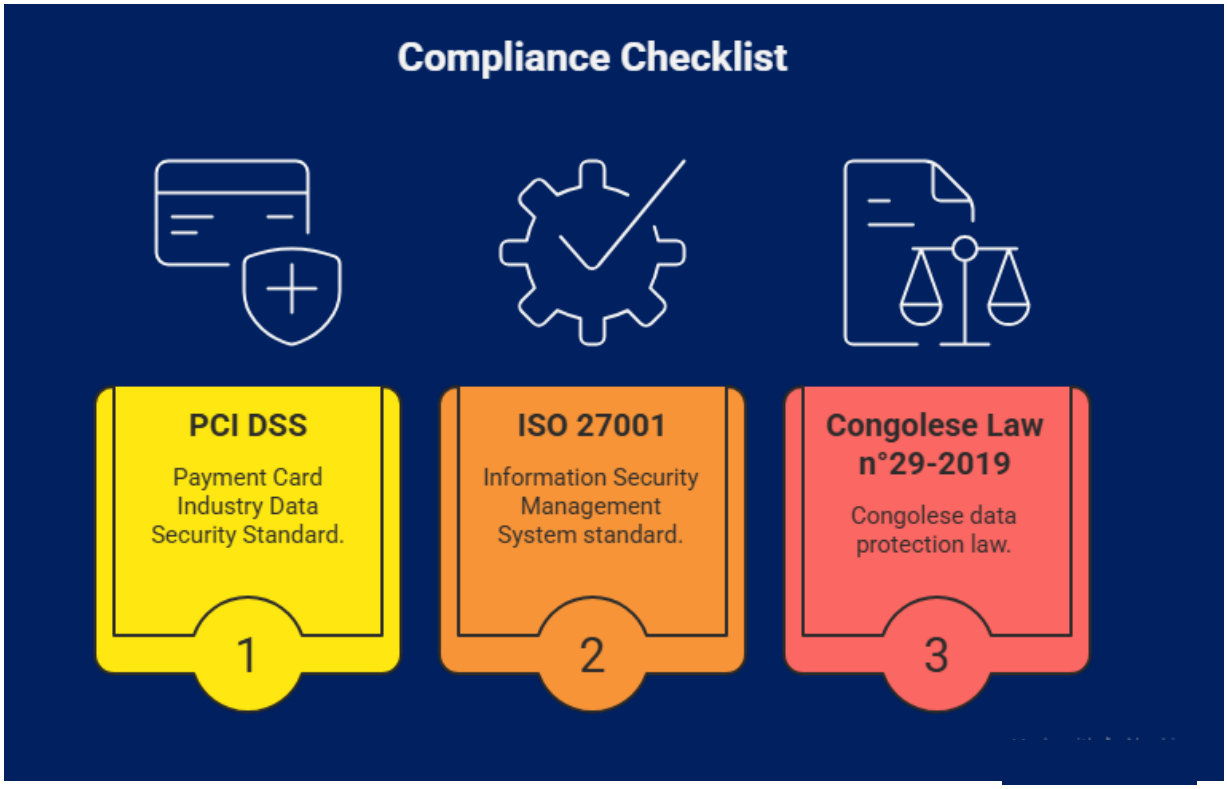


:

10. Compliance and Audit Policy

Regular audits are conducted to verify that security policies are being followed.

Example: An annual internal assessment is performed to ensure that all data processing complies with **Congolese Law No. 29-2019**.



V. Emergency Plan: What to do in case of an incident?

1. Identifying Risks

This involves, for example, identifying ransomware that is locking the servers.

2. Proactive Detection

- Log Monitoring: Using tools like Snort to monitor system logs.
- Real-time Analysis: Analyzing network alerts in real-time.

3. Rapid Response

- Immediate Isolation: Promptly disconnecting compromised systems.
- Notification: Informing affected customers and partners.

4. Recovery

- Data Restoration: Restoring data via system backups and replications.
- Patching: Implementing fixes to close the exploited vulnerabilities.

5. Continuous Improvement

Documenting the incident and drawing lessons learned to prevent a recurrence.

V. Conclusion :

In conclusion, with these defined policies and a robust emergency plan, **SRI Pay En Ligne** will be fully equipped to protect its customers' data, ensure service continuity, and maintain regulatory compliance. Cybersecurity is a never-ending race: these policies must be regularly updated to keep pace with emerging threats and to mitigate the risk of sophisticated attacks, such as **"zero-day"** exploits.